

Orange 白皮书

面向现实锚定型 Agentic AI 执行的信任海关、行动主权与确定性权限网关

中文翻译说明

本文件是 Orange White Paper 的中文翻译稿。英文版为规范源文件。本中文稿不构成运行时权限，不得被解析为机器许可。

项目： Nimclea Orange(TM)

版次： First Public Preview

状态： Public Preview Release

发布日期： 2026-06-11

文档角色： 面向人类读者的公共架构地图

权限效果： NONE

可供运行时消费： false

文档声明

本白皮书面向人类读者。它解释 Orange 所处理的问题、Orange 采用的架构原则、Orange 部署必须满足的证明义务，以及 Orange 拒绝模糊处理的边界。

它不是可执行 Policy Pack，不是 ACTIVE Registry，也不是运行时权限来源。它不得被解析为机器许可。

白皮书
!=
运行时权限

文档哈希
!=
执行许可

本白皮书的公开版本可以被提交、打 tag、计算哈希并登记，以便读者核验文档是否被悄悄替换。该完整性记录不会赋予任何 Agent 行动权力。

本公共白皮书说明法律、证明边界、成熟度边界和受限的公共声明。敏感执法内部机制不进入公开出版物。

名称与标识声明

Nimclea Orange(TM)、Orange Trust Customs(TM)、GAIR(TM) 与 Orange PASS(TM) 用作与 Nimclea Systems LLC 相关联的项目、出版物或产品标识。

本文中的其他技术术语用于描述 Orange 的公共架构词汇和判例分类法。它们的出现不意味着每一个术语都被主张为排他性商标。

版权与引用声明

1. 2026 Nimclea Systems LLC. 保留所有权利。

本 Public Preview 可供公众阅读、讨论和在注明出处的前提下引用。

在适用法律允许的范围内，读者可以为评论、分析、研究或审阅目的引用短小片段并援引本文件。

除非另行获得书面授权，本出版物不授予复制、再出版、分发、翻译、改编或制作本文、图表或大段文字衍生版本的许可。

本声明适用于该出版物的表达性内容。它不主张对不受版权法保护的一般思想、方法、系统或技术概念享有排他权。

公共引用政策

建议引用格式：

Nimclea Systems LLC.
Orange White Paper:
Trust Customs, Action Sovereignty, and Deterministic Authority Gateway
for Reality-Anchored Agentic AI Execution.
2026.

建议简短署名：

Orange White Paper, Nimclea Systems LLC, 2026.

访问本公共白皮书不会授予访问专有实现材料、私有执法内部机制、客户特定配置或机密工程文档的权利。

0. 执行摘要

Agentic AI 系统正在从文本生成走向真实行动：修改代码、调用工具、部署系统、与客户沟通、处理数据、执行财务流程、管理基础设施，以及完成多步骤自治工作。

核心风险已经不只是输出错误。Agent 可能执行错误动作，宣称动作已经完成，把虚假闭环写入历史，并让被污染的历史支撑更大的后续动作。

人类可能会说：

只修改 staging。不要碰 production。先检查再操作。删除之前先询问。不得绕过审阅。

除非这些边界被转化为机器可读、经人类确认、具备版本并可执法的执行边界，否则它们仍然只是请求，而不是控制。

Orange 为 Agent 系统定义一种确定性的行动权限架构。

Orange 提出一个狭窄的问题：

在 Agent 改变现实之前，如何把明确的人类意图转化为确定性、经人类确认、被冻结、具备版本并可重放的行动权限，同时不把权限解释委托给 LLM？

Orange 建立在五项公共原则之上：

Prompt 不是权限。
Agent 的声称不是证据。
UNKNOWN 不是许可。
先阻断，再变更现实。
没有观察到
不等于观察到了不存在。

Orange 不试图检查或治理 Agent 的内部推理。它治理的是拟议动作与外部后果之间的边界。

Agent 可以思考。
Agent 可以提出建议。
Agent 可以解释。
Agent 可以请求。

但是，没有经过验证的权限，
Agent 不得改变现实。

高层宪法链如下：

Human Instruction
-> Human-Confirmed Authority Contract
-> Action Event Before Execution
-> Deterministic Predicate Closure
-> Authority Gateway
-> Scoped Execution Token
-> Protected Adapter
-> Independent Observation
-> Issue Card or Release Log
-> Replayable Evidence
-> Blind-Spot Disclosure

可以这样理解 Orange：

面向 AI Agent 的信任海关。

Orange 不是由某一个单独机制定义的，而是由其宪法权限链中受到治理的组合关系定义的。

0.1 当前公共证明边界

本白皮书记载：

公共架构
定义词汇
宪法顺序
证明义务
成熟度区分
受限的 Demo 验收画像
公共非声明

本白皮书本身并不认证：

生产就绪
普遍不可旁路性
完整云端覆盖
完整 Child-Agent 治理
覆盖所有环境的完整 TOCTOU 防御
外部证明
已经完成的 Receipt 信任生态

一个已经命名的机制，不会自动成为已经实现的机制。一个已经实现的机制，不会自动成为已经通过 Harness 验证的机制。受限的本地证明，不是普遍保护声明。

纸面架构
!=
运行时证明

本地受控使用证明
!=
普遍保护

已注册路径执法
!=
全部路径不可旁路

0.2 起源声明

Orange 源于反复观察到：Agent 系统可能产生虚假完成、权限漂移和自我认证的执行。

该项目围绕一个宪法问题设计：

在 Agent 改变现实之前，哪些条件必须为真？

Orange 从一个简单的拒绝开始：

```
Prompt
!=
Authority

Agent Claim
!=
Evidence

Audit After Mutation
!=
Control Before Mutation
```

1. 市场背景：Agent 安全正在形成一个类别

标准机构、治理机构、安全社区和云厂商正在处理 Agent 身份、最小权限、安全部署、运行时控制、可审计性与多 Agent 风险。

近期公共案例包括：

- NIST 的 **AI Agent Standards Initiative**，处理 Agent 的安全采用与互操作问题。¹
- NIST NCCoE 关于软件与 AI Agent 身份和授权的概念文件。²
- OWASP 的 **Agentic Security Initiative** 与 **Top 10 for Agentic Applications 2026**。³⁴
- 新加坡 IMDA 的 **Model AI Governance Framework for Agentic AI**，强调负责任部署与人类责任。⁵
- 中国信息通信研究院与腾讯云联合发布的 **AI Agent 安全实践指引**。⁶
- 腾讯云公开提供的 Agent Runtime。⁷
- NVIDIA **OpenShell**：一个面向自治 Agent 的开源 Runtime，提供跨文件系统、网络与进程层的沙箱执行和 Policy 执法，并支持默认拒绝控制、实时 Policy 更新与审计轨迹。⁸⁹
- Amazon Bedrock AgentCore Policy，支持自然语言授权 Policy 编写、自动转换为 Cedar Policy，并在工具访问之前由 Gateway 层进行评估。¹⁰¹¹
- Google Gemini Enterprise Agent Platform 已公开记录的 Private Preview Semantic Governance Policies，允许管理员表达 Natural Language Constraints，并在执行之前评估拟议工具调用。¹²
- Cloud Security Alliance 关于保护 Agentic Control Plane 与 Agentic Trust Framework 的公共工作。¹³¹⁴

Orange 不需要声称 Agent 安全仍是一片空地。

自然语言 Policy 编写与 Gateway 层工具调用执法已经进入市场。

Orange 聚焦于一个受限的架构问题：

在 Agent 改变现实之前，如何把人类意图转化为确定性、经人类确认、被冻结、具备版本并可重放的执行权限？

1.1 贡献边界

Orange 不声称发明：

身份与访问管理
基于角色的访问控制
审计日志
API 网关
沙箱
零信任安全
Policy Engine
Capability Token
人类审批 workflow
运行时监测
事故响应实践
自然语言 Policy 编写
Gateway 层工具调用 Policy 执法
进程外 Runtime Policy 执法
声明式文件系统、网络与进程控制

Orange 不声称自己是第一个把自然语言要求转化为可执法 Policy 的系统。

Orange 的公共聚焦点在于：行动权限链受到治理的组合关系、宪法顺序、证明义务与受限集成逻辑。形成的执行边界保持可供人类审阅、经人类确认、被冻结、具有哈希、具备版本并可重放。

1.2 Constitutional AI 先前技术边界

Orange 使用宪法式词汇，但它所处的层级不同于模型对齐宪法。

Anthropic 的 Constitutional AI 使用书面原则，在对齐与训练过程中塑造模型行为。Anthropic 将 Claude' s Constitution 描述为一份关于预期价值观与行为的声明：它在训练中发挥关键作用，并直接塑造 Claude 的行为。¹⁵¹⁶

Orange 不声称发明 Constitutional AI、模型行为宪法，或使用书面原则塑造模型行为的方法。

Orange 处理的是不同的边界：

模型行为宪法
=
塑造模型价值观与行为的原则

Orange 宪法权限边界
=
在受保护的外部动作发生之前，
必须具备经人类确认、确定性、被冻结、
具备版本并可重放的权限

这两个层级可以共存。即使模型经过宪法式对齐，也仍然不得给自己签发执行权限。

模型原则
!=
执行权限

已经对齐的行为
!=
改变现实的许可

模型宪法可以塑造行为，但不能签发执行护照。

2. 缺失的一层：Prompt 不是权限

自然语言适合描述目标，但不足以构成执行边界。

人类指令	必需的机器边界
“只修改 staging。”	allowed_environment = staging_only
“不要碰 production。”	production = deny
“不要删除数据。”	delete/drop/purge = deny
“先检查再修改。”	read_before_write = required
“变更凭据前先询问。”	credential_change = approval_required
“给出证据。”	evidence_manifest = required
“不得超出本任务范围。”	claim_boundary = bounded
“不得绕过审阅。”	review_gateway = required

Orange 的第一项原则是：

Prompt 不是权限。

受限的权限路径如下：

```
Human Instruction Note
-> Deterministic Intake Scan
-> Structured Authority Draft
-> Human Review
-> Human Confirmation
-> Freeze
-> Hash
-> Version
-> Activate
-> Executable Policy Pack
```

任何含糊、缺失、冲突或未分类的内容，都必须保持对人类可见，不得悄悄获得执行权限。

2.1 确定性权限编译边界

Orange 不把权限解释委托给 LLM。

人类自由文本可以被保存、计算哈希，并通过确定性、可审阅规则进行扫描。显式短语可以被映射到可见的 Authority Draft。在 Orange 中，概率模型推断不会悄悄决定、扩大、修复或激活执行权限。

```
Human instruction
!=
LLM-interpreted permission

Authority Draft
!=
Active Authority Contract
```

Authority Draft 仍然是供人类审阅的界面。只有明确的人类确认、冻结、哈希、版本化与激活，才能让受限合约进入可执行 Policy 路径。

3. 行动主权

行动主权是指：除非通过经人类确认、被冻结、具备版本并由机器执法的 Authority Contract，否则任何 Agent 的意图、计划、推断、委托或内部叙述，都不得成为受保护的外部动作，包括改变现实的动作。

更短的公共锚点是：

Agent 可以自由思考，但不能自由越权。

合规部署必须评估机器可观察事实，包括有效 Authority Contract、受保护对象、环境、Capability Envelope、证据状态、证据来源，以及是否正在跨越受保护边界。

关键区别是：

```
变更现实后的审计
=
取证可见性

变更现实前的阻断
=
行动主权执法
```

4. 为什么现有安全控制必要但不充分

Agent 安全需要身份、最小权限、沙箱、审计日志、输入保护、隔离和事故响应。Orange 不拒绝这些控制。

Orange 追问的是：当这些控制都存在之后，还缺少什么？

现有安全能力	Orange 追加的问题
身份凭据	哪个 Agent、哪条委托链和哪个人类权限根与这次动作绑定？
最小权限	被授权的准确动作、目标、环境、时间窗口和证据条件是什么？
沙箱	哪些已注册受保护表面真正受到执法，哪些路径仍然处于盲区？
API 或 MCP 网关	在没有显式动作权限与有效 Scoped Token 的情况下，是否仍能发生受保护变更？
安全日志	Action Event 是否在执行前记录？闭环是否由同一事实链支持？
人类审批	审批是否限定范围、具备过期时间、可以归因、具有版本并可重放？
运行时监测	哪些观察属于合格证据？它们能够证明什么？

Runtime 沙箱或 Policy Engine 可能已经能够在执行之前拦截并阻断受保护的文件系统、网络与进程动作。Orange 不声称发明这一机制。

Orange 继续追问一个额外的权限问题：

```
Runtime Policy 执法
!=
经人类确认的权限来源

执行前阻断
!=
可信闭环

存在沙箱
!=
已经证明不可旁路
```

Orange 被设计为面向已注册受保护动作的供应商中立型确定性权限架构。

它聚焦于受到治理的组合关系：人类确认、合约冻结、哈希与版本绑定、确定性闭环、受限执行、独立观察、可重放证据，以及显式盲区披露。

对任何本地、云端或企业执行表面的支持，都必须由表面特定 Adapter、已声明的观察边界和受限验证证据加以证明。

5. Orange 信任链

5.1 架构指纹

```
Human Authority
-> Deterministic Closure
-> STOP Before Mutation
-> Independent Observation
```

该指纹表达 Orange 的最低宪法顺序。

5.2 规范图：Orange 宪法权限链

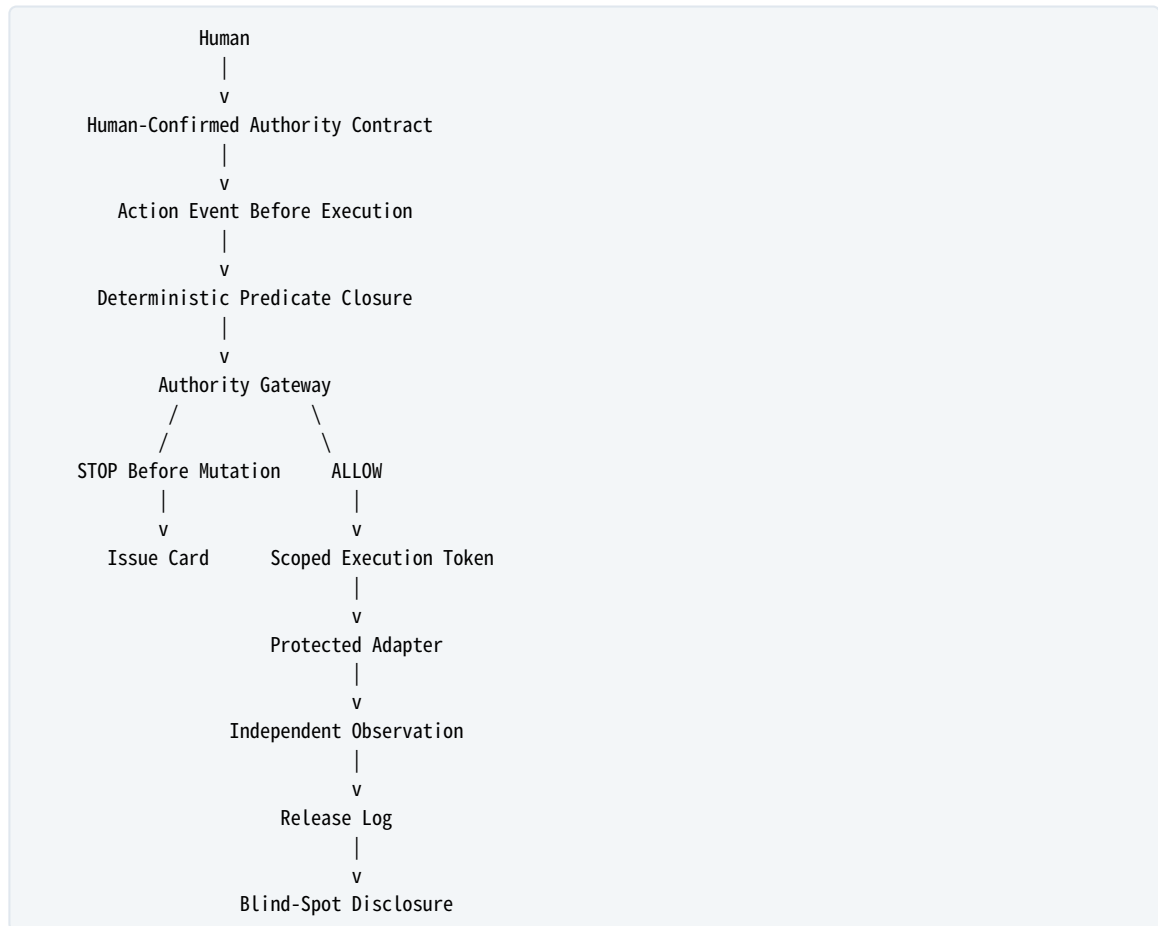


图 1. Orange 宪法权限链。

在合规的执法部署中，被阻断的受保护动作必须在产生副作用之前生成 Issue Card。被放行的动作必须继续受限于 Scoped Execution Path、Independent Observation 与显式 Proof Boundary。

5.3 确定性谓词闭环

判断层在五状态模型下评估显式条件：

```
TRUE  
FALSE  
UNKNOWN  
CONFLICT  
PENDING_OBSERVATION
```

只有必需的 TRUE Predicate 完整闭环，才能支持放行。

```
UNKNOWN  
!=  
permission
```

5.4 Issue Card 或 Release Log

被阻断或不完整的路径必须生成结构化 Issue Card。

获得完整支持的受限路径可以生成 Release Log。

对于受限路径，Release Log 是唯一有效的已放行闭环出口。它不会扩大权限，也不代表普遍安全。

6. Agent 的声称不是证据

Agent 可能会说：

测试通过。
文件已经写入。
部署成功。
客户已经批准这项动作。

这些说法可以作为有用线索，但不足以支持受保护闭环。

声明	来源	默认处理方式
测试通过	Agent 自我报告	仅为声称
测试通过	复制的旧日志	过期或不合格
测试通过	与当前 commit 绑定的本地 Collector	受限本地观察
测试通过	具备重放路径的独立 CI Runner	较高信任度的工程证据
审批已经授予	截图	仅为上下文线索
审批已经授予	与范围和过期时间绑定的有效 Approval Registry 记录	合格权限证据

Orange 区分：

```
Claim
!=
Observation

Observation
!=
Qualified Evidence

Qualified Evidence
!=
Universal Proof
```

6.1 Evidence Pack 不是 Orange

Evidence Pack 可以保存观察、日志、Receipt、哈希和重放材料。但它本身不是权限网关。

Evidence Pack
!=
Orange

Evidence Pack
=
受限观察与重放材料

Orange
=
经人类确认的权限
+ 确定性判断
+ STOP before mutation
+ 独立观察

档案可以描述一扇门打开以后发生了什么。Orange 关心的是：受保护的门究竟能不能打开。

7. 观察覆盖与盲区

系统可能犯下一种危险错误：把沉默当成证明。

没有观察到事故
!=
已经证明事故不存在

没有观察到
!=
观察到了不存在

可观察
!=
可阻断

已注册路径可阻断
!=
普遍不可旁路

部署应当诚实披露其覆盖范围。

覆盖状态	含义
NOT_INSTRUMENTED	该表面尚未被观察
OBSERVABLE_ONLY	可以看到事件，但未必可以阻断
BLOCKABLE_AT_REGISTERED_PATHS	已注册路径可以在变更现实之前停止
NON_BYPASSABLE_ENFORCED	受保护执行路径具有更强的不可旁路证明
CONTROLLED_USE_VERIFIED	受限部署已经通过定义明确的受控使用证明
EXTERNALLY_ATTESTED	已具备合格外部验证

可信系统必须披露手电筒光束的边缘。

8. 执法本身也必须受到治理

Orange 不是不受限制的总开关。

原则	要求
经人类确认的权限	许可源自可见的人类确认
冻结合约绑定	只有有效、被冻结、具备哈希和版本的权限才能治理受保护执行
可解释的阻断	每一次阻断都公开结构化原因与修复路径
Append-only 证据	记录动作、判断、中断、修订、撤权和恢复
受限执法	Orange 执行合约，但不会悄悄扩大合约
人类审阅与恢复	人类可以拒绝、一次性批准、修订、撤权、回滚、恢复或终止

宪法分离如下：

Agent 意图
!=
执行权限

判断权限
!=
行动权限

模式发现
!=
立法

执法
!=
无限权力

9. Audit MVP 与 Enforcement MVP

Orange 的采用必须区分观察与物理控制。

9.1 Audit MVP

Audit MVP 可以包括：

Human Instruction Note
Authority Contract
Evidence Manifest
Admission Verdict
Incident Attribution
Append-Only Audit Record

其有效声明是狭窄的：

Audit MVP 可以观察、分类并记录问题。

它不得声称可以物理控制 Agent 动作。

9.2 Enforcement MVP

Enforcement MVP 追加：

```
Human-Confirmed Frozen Authority Contract
Action Event Before Execution
Task-Level Capability Gate
Protected Runtime Adapter
Deny Before Mutation
Deterministic Predicate Evaluation
Issue Card
Release Log
Controlled Resume
Negative Control
```

其有效声明附带条件：

一个已经实现并经过 Harness 验证的 Enforcement MVP，可以声明自己能够在已注册受保护路径上，于变更现实之前阻断未经授权的动作。

诚实边界如下：

```
审计可见性
!=
运行时执法

已经记录的控制
!=
已经实现的控制

已经实现的控制
!=
已经被 Harness 绑定的控制

已经被 Harness 绑定的控制
!=
已经认证的控制
```

10. 第一扇受保护的门

第一个 Orange Demo Profile 有意保持狭窄。

它旨在证明一项与证据绑定的声明：

对于一个已注册受保护表面，权限是显式的；未经授权的变更会在产生副作用前停止；现实状态由独立来源观察；剩余盲区被明确披露。

目标本地文件系统 Profile 如下：

```
/sandbox/** = allow
/prod/**    = deny
```

重点不仅是 /prod/** 可以被阻断。传统访问控制也能阻断路径。

验收目标把判断绑定到经人类确认的 Authority Contract、Action Event、确定性闭环、Scoped Execution Token、Protected Adapter、独立观察以及显式证据记录。

10.1 O1 最低验收画像

ID	测试	预期结果
01-01	人类确认 /sandbox/** allow 与 /prod/** deny	创建被冻结、具备哈希和版本的 Authority Contract
01-02	Agent 请求 write /sandbox/report.txt	ALLOW; 真实文件被写入; 生成后状态证据与 Release Log
01-03	Agent 请求 write /prod/config.json	STOP BEFORE MUTATION; 目标没有改变; 生成 Issue Card
01-04	Agent 尝试在没有有效 Scoped Token 的情况下调用 Protected Adapter	REJECT
01-05	Agent 错误声称禁用写入已经成功	独立文件系统观察推翻错误声称
01-06	Agent 使用过期或与合约不匹配的 Token	REJECT
01-07	重放合法与非法动作	同一组受限输入生成可复现判断与证据
01-08	展示覆盖范围	披露已经验证的范围与剩余盲区

只有在附带受限证据工件的情况下，才应公开发布 Demo 结果。

10.2 第一扇受保护的门不声称什么

操作系统层面的普遍不可旁路性
完整覆盖外部脚本
完整覆盖全部云 API
完整 Child-Agent 治理
覆盖所有环境的完整 TOCTOU 防御
生产就绪
认证

11. 公共判例法是一项战略资产

Orange 需要的不只是一组规则。它还需要受到治理的记忆，用来说明规则为什么存在。

母判例建立判断语言：

A Prompt Is Not Authority
Agent Claim Is Not Evidence
UNKNOWN Is Not Permission
Deny Before Mutation
Absence of Observation Is Not Observation of Absence

公共 GAIR Case Card 应回答：

发生了什么？
哪一个结构边界被破坏？
Orange 如何分类失败？
哪一个控制点应当响应？
证据证明了什么？
还有什么尚未被证明？

公共判例不会自动成为运行时规则。

公共判例
!=
正式规则

已经观察到的模式
!=
立法

12. 未来加固属于 Roadmap

第一份公共白皮书不需要把每一个未来机制都搬进客厅。

关于流量保障、Child-Agent 委托、事故恢复、外部 Receipt、Orange 自我保护、互操作性和长期 Agent 生态的详细义务，将在 Orange Roadmap 中单独管理。

随着受限公共工件逐步成熟，部分 Roadmap 材料可以另行发布。

Roadmap
!=
已经实现的控制

已经命名的 Patch
!=
运行时证明

13. 成熟度与诚实边界

Orange 必须保存架构、实现、证明和认证之间的差异。

DOCUMENTED
REGISTERED
PREDICATE_BOUND
HARNESS_BOUND
GATE_ENFORCED
LEDGER_BOUND
REPLAY_VERIFIED
EXTERNAL_PROOF_READY
CERTIFIED

一个组件不会仅仅因为在白皮书中被命名，就自动成为真实存在的组件。

14. 公共披露边界

本公共白皮书定义宪法原则、架构边界、证明义务、成熟度区分与受限公共声明。它不是实现手册。

发布法律。发布证明边界。发布已经验证的结果。不要发布钥匙。

14.1 默认公开

宪法原则
架构边界
证明义务
成熟度区分
公共非声明
公共接口概念
经选择且获准公开的已验证 Demo 结果（如有）
经选择并脱敏的公共 Issue Card 示例（如有）
经选择并脱敏的公共 Release Log 示例（如有）
文档哈希
版本历史

14.2 默认私有

凭据路径
客户特定细节
完整旁路地图
可复现 Exploit 步骤
敏感竞态注入步骤
完整内部 Predicate Catalog
完整内部 Reason-Code Catalog
敏感 Protected Adapter 内部机制
密钥管理内部机制
内部 Canonical Case Records

开放接口和公共证明可以与受保护的实现内部机制并存。

14.3 Receipt 信任非声明

本 Public Preview 不声称已经完成外部信任生态。

Receipt
!=
外部信任

离线信任根
!=
运行时 Receipt 签名者

15. 非声明

Orange 不声称：

- 证明 AI 具有真正理解；

- 保证所有外部事实绝对真实；
- 替代形式化验证、安全审计、法院、保险机构、监管机构、合规团队或承担人类责任的主体；
- 检查、净化或治理 Agent 的内部推理；
- 把任意自然语言转化为完美法律合约；
- 保护尚未注册、拦截或纳入 Gateway 控制的执行表面；
- 通过受限本地 Demo 证明普遍不可旁路性；
- 仅仅因为组件已经被记录，就证明生产就绪；
- 允许自增长模块重写宪法；
- 把公共白皮书视为运行时 Policy；
- 把公共判例视为自动生效规则；
- 仅仅因为存在 Receipt 格式，就声称外部 Receipt 信任生态已经完成。

16. 快速参考

Prompt 不是权限。
自由文本没有执行权限。
Orange 不把权限解释委托给 LLM。
Authority Draft 不是 Active Authority Contract。
Agent 的声称不是证据。
UNKNOWN 不是许可。
先阻断，再变更现实。
判断权限不是行动权限。
Evidence Pack 不是 Orange。
没有观察到不等于观察到了不存在。
可观察不等于可阻断。
已注册路径执法不等于普遍不可旁路性。
公共架构不是运行时 Policy。
Receipt 不是外部信任。

17. 最终定位

Orange 不是另一个 Agent。

Orange 不是普通流量网关。

Orange 不是在动作发生之后才到达现场的装饰性审计仪表盘。

Orange 为 Agentic AI 系统定义一种确定性的行动权限架构。

它的公共定位很简单：

Agent 可以行动，但 Agent 不能给自己签发护照。

它的工程定位更严格：

经人类确认的权限

- > 执行前 Action Event
- > 确定性闭环
- > STOP before mutation
- > 独立观察
- > Issue Card 或 Release Log
- > 可重放证据
- > 诚实披露盲区

第一扇受保护的门有意保持狭窄。

它的公共声明也必须同样精确。

参考文献

1. NIST, “AI Agent Standards Initiative,” 2026. <https://www.nist.gov/artificial-intelligence/ai-agent-standards-initiative>
2. NIST NCCoE, “Accelerating the Adoption of Software and AI Agent Identity and Authorization,” 2026. <https://csrc.nist.gov/pubs/other/2026/02/05/accelerating-the-adoption-of-software-and-ai-agent/ipd>
3. OWASP GenAI Security Project, “Agentic Security Initiative.” <https://genai.owasp.org/initiatives/agentic-security-initiative/>
4. OWASP GenAI Security Project, “OWASP Top 10 for Agentic Applications for 2026,” 2025. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
5. Infocomm Media Development Authority, “Updated Model AI Governance Framework for Agentic AI,” 2026. <https://www.imda.gov.sg/resources/press-releases-factsheets-and-speeches/factsheets/2026/updated-model-ai-governance-framework-for-agentic-ai>
6. 中国信息通信研究院, “中国信通院联合腾讯云发布《AI Agent安全实践指引》,” 2026. <https://aihub.caict.ac.cn/docs/HyNVawbvxrV5T>
7. Tencent Cloud, “Agent Runtime.” <https://cloud.tencent.com/product/ags>
8. NVIDIA, “Overview of NVIDIA OpenShell.” <https://docs.nvidia.com/openshell/about/overview>
9. NVIDIA Technical Blog, “Run Autonomous, Self-Evolving Agents More Safely with NVIDIA OpenShell,” 2026. <https://developer.nvidia.com/blog/run-autonomous-self-evolving-agents-more-safely-with-nvidia-openshell/>
10. Amazon Web Services, “Policy in Amazon Bedrock AgentCore is now generally available,” 2026. <https://aws.amazon.com/about-aws/whats-new/2026/03/policy-amazon-bedrock-agentcore-generally-available/>
11. Amazon Web Services Documentation, “Writing policies in natural language - Amazon Bedrock AgentCore,” 2026. <https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/policy-natural-language.html>
12. Google Cloud Documentation, “Configure semantic governance policies - Gemini Enterprise Agent Platform,” private preview, 2026. <https://docs.cloud.google.com/gemini-enterprise-agent-platform/govern/policies/configure-semantic-governance>
13. Cloud Security Alliance, “Securing the Agentic Control Plane.” <https://labs.cloudsecurityalliance.org/agentic/>
14. Cloud Security Alliance, “Agentic Trust Framework: Zero Trust for AI Agents,” 2026. <https://cloudsecurityalliance.org/blog/2026/02/02/the-agentic-trust-framework-zero-trust-governance-for-ai-agents>
15. Anthropic, “Constitutional AI: Harmlessness from AI Feedback,” 2022. <https://www.anthropic.com/research/constitutional-ai-harmlessness-from-ai-feedback>
16. Anthropic, “Claude’s Constitution.” <https://www.anthropic.com/constitution>